E1 UK GDPR and special category data in HR

Generated from the same content files as the app. Each module lists its roadmap months. Solutions are in the appendix.

Contents

Track E: Data protection and governance 2

E1 UK GDPR and special category data in HR 3

E1-L1 Personal data, special category data and the two-part test 3

E1-L2 A lawful basis for each use of talent data 7

E1-L3 Article 9 conditions, policy documents and DPIA screening in HR 11

E1-L4 Writing the DPIA for a people model 16

E1-L5 Personal data in each medallion layer 20

Track E best-practice checklist 25

Appendix: solutions and answer keys 26

Track E: Data protection and governance

The law and the frameworks that govern people data, for the engineer who builds the platform.

E1 UK GDPR and special category data in HR

Roadmap: EY Talent Data Strategy role; Current work. Personal and special category data, lawful bases for talent data, Article 9 conditions, appropriate policy documents and DPIA screening.

E1-L1 Personal data, special category data and the two-part test

Concept

Everything a talent platform holds is **personal data**: names, grades, salaries, review scores, course completions, skills. It relates to an identifiable person, so the UK GDPR applies. The Data Protection Act 2018 sits beside it and adds UK-specific conditions. These lessons follow the ICO's guidance as of November 2026. Your data protection officer and legal team make the final call.

Some personal data needs more protection. The UK GDPR names nine **special categories** in Article 9:

- racial or ethnic origin
- political opinions
- religious or philosophical beliefs
- trade union membership
- genetic data
- biometric data, when you use it to identify someone uniquely
- health
- sex life
- sexual orientation

Three details catch engineers out.

Biometric data is narrow. A staff photo on a profile is not special category data. The same photo used to unlock a door by face recognition is.

Inferences count. A model that infers health, ethnicity or sexual orientation from other fields processes special category data, even when no column is called that.

Protected characteristics are a different list. Age and sex are protected under the Equality Act 2010, but they are not special categories. Sexual orientation and religion are both.

To use any personal data you need a **lawful basis** under Article 6. To use special category data you need a lawful basis **and** an **Article 9 condition**. This is the **two-part test**. Lessons E1-L2 and E1-L3 cover each part.

Why it matters

An HR analytics team built an attrition model from absence records, overtime and the free-text reasons managers gave for sick leave. The model's strongest feature was a word count of "stress" and "anxiety" in those reasons. Nobody had flagged the column, because it was called absence_note. It held health data, so the processing needed an Article 9 condition and a data protection impact assessment that nobody had done. The model was withdrawn for three months while the team removed the field and wrote the assessment.

Worked example: weak code

```
# Attribute register, talent platform
date_of_birth: {sensitive: true}
gender: {sensitive: true}
absence_note: {sensitive: false}
badge_photo: {sensitive: true}
union_rep: {sensitive: false}
```

1. **Line 2.** One yes/no flag mixes up two lists. Age is a protected characteristic, not a special category.
2. **Line 4.** Free text about sick leave holds health data.
3. **Line 6.** Being a union representative reveals trade union membership, a special category.

Worked example: strong code

```
# Attribute register, talent platform
date_of_birth: {special_category: null, protected_characteristic: age}
gender: {special_category: null, protected_characteristic: sex}
absence_note: {special_category: health, protected_characteristic: null}
badge_photo: {special_category: null, note: "biometric only if used to
  identify"}
union_rep: {special_category: trade_union_membership,
  protected_characteristic: null}
```

1. **Line 2.** Two separate fields: the GDPR list and the Equality Act list.
2. **Line 4.** Classified by what the content reveals, not by the column name.

3. **Line 5.** Records the condition that would change the classification.

Classify each attribute by what it reveals. Keep the special categories and the protected characteristics as two separate fields, and treat inferences as data.

Recap card

- **The nine special categories** Racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic, biometric (to identify), health, sex life, sexual orientation.
- **Is an inferred special category special category data?** Yes. A model that infers health or ethnicity processes special category data.
- **Age and sex** Protected characteristics under the Equality Act 2010. Not special categories.
- **The two-part test** An Article 6 lawful basis for all personal data, plus an Article 9 condition for special category data.

Practice

Exercise 1. Multiple choice (level 1)

Which attribute is special category data under Article 9 of the UK GDPR?

- a) Date of birth
- b) Salary band
- c) Trade union membership
- d) Home address

Exercise 2. Multiple choice (level 2)

A model predicts which employees are likely to go on long-term sick leave, from absence patterns and overtime. No input column holds health data. Does the processing involve special category data?

- a) No, because no input column is health data
- b) Yes, because the model infers information about health
- c) Only if the predictions are shown to managers
- d) Only if the model uses more than 1,000 records

Why?

- r1) Inferring a special category from other data counts as processing that category.
- r2) Absence data is always health data.

Exercise 3. Fill the gap (level 2)

Complete the two-part test for using special category data.

```
Part 1: a lawful basis under Article _____(1)
Part 2: a condition under Article _____(2)
```

Exercise 4. Write the function (level 3)

Write `is_special_category(field: dict) -> bool` for an attribute register. `field` has a `"category"` key, such as `"health"` or `"age"`, and may have a `"use"` key. Return True for the nine special categories. Biometric data counts only when `field.get("use") == "identify"`. Keep the category names in a module constant.

The category names are: `"racial_or_ethnic_origin"`, `"political_opinions"`, `"religious_or_philosophical_beliefs"`, `"trade_union_membership"`, `"genetic"`, `"biometric"`, `"health"`, `"sex_life"` and `"sexual_orientation"`.

Your code must pass these checks:

- Return True for each of the nine special categories.
- Age and sex are protected characteristics, not special categories. Salary and address are ordinary personal data.
- Biometric data is special category data only when you use it to identify someone uniquely.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```python
# Module constant.
SPECIAL_CATEGORIES = ...

# True when an attribute is special category data under Article 9.
def is_special_category(field: dict) -> bool: ...
```

Starter code:

```python
def is_special_category(field):
    return field["category"] in {"health", "age", "biometric"}
```

Exercise 5. Architecture design (level 4)

Design the classification fields for a talent attribute register that feeds access rules and DPIA screening.

Options: special_category and protected_characteristic as separate fields, One sensitive: true/false flag.

1. Fields for sensitivity
2. How an attribute is classified

3. Model outputs

Sources

- UK GDPR Article 9 lists nine special categories; biometric data counts only when used to identify someone uniquely; age is not among them but is a protected characteristic under section 4 of the Equality Act 2010; special category data needs an Article 6 basis and an Article 9 condition. (verified: https://www.legislation.gov.uk/eur/2016/679/article/9 and https://www.legislation.gov.uk/ukpga/2010/15/section/4, checked 7 November 2026.)
- Inferring a special category means processing special category data. (search-only: ICO guidance pages 'What is special category data?', 'Biometric recognition: key data protection concepts' and 'What about fairness, bias and discrimination?' (ico.org.uk), seen through search results, November 2026. ico.org.uk was not reachable from the build environment.)
- The Data Protection Act 2018 supplements the UK GDPR with UK-specific conditions in Schedule 1. (verified: https://www.legislation.gov.uk/ukpga/2018/12/section/10, checked 7 November 2026.)

E1-L2 A lawful basis for each use of talent data

Concept

Article 6 of the UK GDPR gives **seven lawful bases**. Each use of personal data needs one that fits it:

- **consent**
- **contract**, to perform a contract with the person, such as paying their salary
- **legal obligation**, such as tax reporting or right-to-work checks
- **vital interests**, to protect someone's life
- **public task**
- **legitimate interests**
- **recognised legitimate interests**

The seventh came with the Data (Use and Access) Act 2025 on 5 February 2026. It covers only the purposes listed in Annex 1 of the UK GDPR, such as safeguarding, crime and emergencies, and it has no balancing test. Workforce analytics is not on the list.

Employers rarely rely on consent. The ICO's view is that the power imbalance between employer and worker makes it hard for consent to be freely given. A worker who fears saying no has no genuine choice. Use another basis.

Workforce analytics usually rests on **legitimate interests**. The ICO describes a **three-part test**, recorded in a **legitimate interests assessment** (LIA) before processing starts:

1. **Purpose**: is there a legitimate interest?
2. **Necessity**: does the processing serve it, and is there a less intrusive way?
3. **Balancing**: do the person's interests, rights and freedoms override yours? Ask what a reasonable person would expect.

Two principles from Article 5 shape the platform. **Purpose limitation**, Article 5(1)(b): a basis covers the purposes you specified. Payroll under contract does not cover an attrition model. A new purpose needs its own check. **Data minimisation**, Article 5(1)(c): hold only the data each purpose needs.

Why it matters

A firm launched an engagement survey and stated that consent was its lawful basis. Two years later it fed the answers into a promotion-readiness model. Staff complained that they had never agreed to that use, and some withdrew consent, which removed their records from every analysis. A legitimate interests assessment for each purpose, done before launch, would have shown that the promotion use failed the balancing test.

Worked example: weak code

```
  1 # Processing register, talent platform
(1) payroll: {lawful_basis: consent}
  3 engagement_survey: {lawful_basis: consent}
(2) attrition_model: {lawful_basis: same as payroll}
```

1. **Line 2.** Workers cannot refuse payroll. Consent cannot be freely given here.
2. **Line 4.** A new purpose needs its own basis check. Payroll's basis does not stretch to it.

Worked example: strong code

```
  1 # Processing register, talent platform
(1) payroll: {lawful_basis: contract}
  3 tax_reporting: {lawful_basis: legal_obligation}
(2) engagement_survey: {lawful_basis: legitimate_interests, lia: LIA-007}
```

```
❸ attrition_model: {lawful_basis: legitimate_interests, lia: LIA-012,
    fields: minimised}
```

1. **Line 2.** Paying salary performs the employment contract.
2. **Line 4.** Each use of legitimate interests points to its recorded assessment.
3. **Line 5.** Its own assessment, and only the fields the model needs.

Give each purpose its own lawful basis, avoid consent for workers, record a legitimate interests assessment for each use of legitimate interests, and keep only the fields each purpose needs.

Recap card

- **The seven lawful bases** Consent, contract, legal obligation, vital interests, public task, legitimate interests, and recognised legitimate interests since 5 February 2026.
- **Consent for employee data** Rarely appropriate. The power imbalance makes it hard to give freely. Use another basis.
- **Legitimate interests assessment** Purpose, necessity, balancing, recorded before processing starts.
- **Purpose limitation** A basis covers the purposes you specified. A new purpose, such as an attrition model, needs its own check.
- **Recognised legitimate interests** Article 6(1)(ea), from 5 February 2026. Only the purposes in Annex 1, with no balancing test.

Practice

Exercise 1. Multiple choice (level 1)

Which lawful basis fits paying an employee's salary?

- a) Consent
- b) Contract
- c) Vital interests
- d) Public task

Exercise 2. Multiple choice (level 2)

A team wants to use consent as the lawful basis for a voluntary skills survey of its own employees. What does the ICO's guidance say?

- a) Consent is the safest basis for any employee data
- b) Employers rarely rely on consent, because the power imbalance makes it hard to give freely
- c) Consent is banned for employees

- d) Consent is required for any survey

Why?

- r1) A worker who fears refusing has no genuine choice, so consent is hard to show as freely given.
- r2) Consent expires after one year.

Exercise 3. Put in order (level 2)

Put the steps of a legitimate interests assessment in order.

- Balancing: weigh the person's interests, rights and freedoms against yours
- Purpose: identify the legitimate interest
- Record the outcome before processing starts
- Necessity: show the processing serves it and nothing less intrusive would

Exercise 4. Fill the gap (level 3)

Complete the two principles that shape a talent platform.

```
Purpose _____(1): a lawful basis covers the purposes you specified. A new purpose needs its own check.
Data _____(2): hold only the data each purpose needs.
```

Exercise 5. Architecture design (level 4)

Choose the lawful basis for each use of a talent platform's data.

Options: Legal obligation, Consent, Legitimate interests.

1. Right-to-work checks before someone starts
2. Recording mandatory training completions
3. A new attrition prediction model

Sources

- Article 6(1) lists seven lawful bases since 5 February 2026; point (ea) is recognised legitimate interest. Purpose limitation is Article 5(1)(b) and data minimisation Article 5(1)(c). Article 8A sets the test for whether a new purpose is compatible. (verified: https://www.legislation.gov.uk/eur/2016/679/article/6, /article/5 and /article/8A, checked 7 November 2026.)
- Consent is not usually appropriate for employers because of the imbalance of power; not banned where refusing has no adverse consequences. (search-only: ICO guidance 'Data protection and monitoring workers' and 'Data protection and workers' health information' (ico.org.uk), seen through search results, November 2026.)

- Legitimate interests three-part test: purpose, necessity, balancing; reasonable expectations judged objectively; record in an LIA before processing. (search-only: ICO guidance 'What is the legitimate interests basis?' and 'Legitimate interests' (ico.org.uk), seen through search results, November 2026.)
- Recognised legitimate interests came into force on 5 February 2026 (section 70, SI 2026/82). Under Article 6(5) the basis applies only if processing meets a condition in Annex 1, with no balancing clause. (verified: https://www.legislation.gov.uk/uksi/2026/82/made and https://www.legislation.gov.uk/eur/2016/679/article/6, checked 7 November 2026.)

E1-L3 Article 9 conditions, policy documents and DPIA screening in HR

Concept

Article 9(2) of the UK GDPR lists ten conditions for special category data. Two carry most HR work, and in the UK both need an extra condition from **Schedule 1 of the Data Protection Act 2018**.

Article 9(2)(b), employment, social security and social protection. It covers duties and rights in employment law, such as recording sickness absence or making reasonable adjustments. The UK condition is Schedule 1, Part 1, **paragraph 1**. It does not cover purely contractual rights.

Article 9(2)(g), substantial public interest. It needs one of the 23 conditions in Schedule 1, **paragraphs 6 to 28**. Diversity monitoring usually relies on **paragraph 8, equality of opportunity or treatment**. It covers four categories only: racial or ethnic origin, religious or philosophical beliefs, health, and sexual orientation. Paragraph 8 supports reviewing equality across groups. It cannot support a decision about one person, so keep monitoring data apart from promotion or hiring decisions.

Both routes need an **appropriate policy document** (APD). The ICO says it needs no set form. It names the Schedule 1 condition, explains how you meet the principles, and sets your retention and erasure rules. One APD can cover several purposes. Your record of processing activities also names the condition.

Before you start processing likely to result in **high risk**, carry out a **data protection impact assessment** (DPIA) under Article 35. Three cases

always need one, including **large-scale special category or criminal offence data** and extensive profiling with significant effects. The ICO's list adds others, such as innovative technology like AI combined with another risk factor. Two risk factors usually mean a DPIA. If you cannot reduce a high risk, consult the ICO before you start. Since 30 September 2026 the ICO is the Information Commission's Office.

Why it matters

A retailer used its equal opportunities survey, collected under paragraph 8, to pick candidates for a leadership programme that favoured under-represented groups. The survey data now drove decisions about individuals, which paragraph 8 does not support. The programme paused while the team rebuilt it on aggregate statistics and a separate, voluntary application form.

Worked example: weak code

```
  1 # Special category register
❶ sickness_absence: {article_9: 9(2)(b)}
❷ ethnicity: {article_9: 9(2)(g), used_for: [diversity_report,
    promotion_shortlist]}
❸ dpia: not needed, internal data only
```

1. **Line 2.** No Schedule 1 condition and no appropriate policy document.
2. **Line 3.** Paragraph 8 supports monitoring, not decisions about individuals.
3. **Line 4.** Large-scale special category data needs a DPIA, internal or not.

Worked example: strong code

```
  1 # Special category register
❶ sickness_absence: {article_9: 9(2)(b), schedule_1: "Part 1 para 1", apd:
    APD-HR-01}
❷ ethnicity: {article_9: 9(2)(g), schedule_1: "Part 2 para 8", apd: APD-
    HR-01, used_for: [diversity_report]}
❸ dpia: DPIA-014, screened for large-scale special category data and
    profiling
```

1. **Line 2.** Article 9 condition, Schedule 1 condition and the policy document, side by side.
2. **Line 3.** Monitoring only. No individual decisions.
3. **Line 4.** The screening reason is recorded with the assessment.

Pair each Article 9 condition with its Schedule 1 condition and an appropriate policy document, keep monitoring data away from individual decisions, and screen every new use for a DPIA.

Recap card

- **Employment condition in the UK** Article 9(2)(b) plus Schedule 1, Part 1, paragraph 1 of the DPA 2018, with an appropriate policy document.
- **Diversity monitoring** Article 9(2)(g) plus Schedule 1 paragraph 8, equality of opportunity or treatment. Never for decisions about one person.
- **Appropriate policy document** Names the Schedule 1 condition, how you meet the principles, and retention and erasure. One APD can cover several purposes.
- **When a DPIA is mandatory** Before high-risk processing, always for large-scale special category data and extensive profiling with significant effects. Consult the ICO if high risk remains.

Practice

Exercise 1. Multiple choice (level 1)

Which conditions does diversity monitoring of employees usually rely on?

- a) Article 9(2)(g) with Schedule 1 paragraph 8, equality of opportunity or treatment
- b) Article 9(2)(b) with Schedule 1 paragraph 1
- c) Consent from each employee
- d) No condition, because the data is aggregated afterwards

Exercise 2. Multiple choice (level 2)

A team wants to use the ethnicity answers from the equal opportunities survey to shortlist candidates for a promotion programme. What is the problem?

- a) None, the data is already collected
- b) Paragraph 8 supports monitoring equality across groups, not decisions about one person
- c) Ethnicity is not special category data
- d) The survey must be repeated each year

Why?

- r1) The ICO says the equality condition cannot be relied on when processing is for decisions about a particular individual.
- r2) Survey data expires after six months.

Exercise 3. Fill the gap (level 2)

Complete the documentation rule for the employment condition.

```
Article 9(2)(b) in the UK needs Schedule 1, Part 1, paragraph _____(1)
and an appropriate _____(2) document that names the condition and the
    retention rules.
```

Exercise 4. Write the function (level 3)

Write `check_register(entries: list[dict]) -> list[str]` for a processing register. Each entry has `"attribute"`, `"special"` (a bool), `"lawful_basis"`, `"condition"`, `"schedule1"` and `"apd"` (a bool). `"condition"` and `"schedule1"` may be None. Return one message per problem, in register order:

- `"<attribute>: no lawful basis"` when `lawful_basis` is not one of the six bases (`"consent"`, `"contract"`, `"legal_obligation"`, `"vital_interests"`, `"public_task"`, `"legitimate_interests"`)
- `"<attribute>: no Article 9 condition"` when the attribute is special and `condition` is None
- `"<attribute>: no Schedule 1 condition"` when `condition` is `"9(2)(b)"` or `"9(2)(g)"` and `schedule1` is None
- `"<attribute>: no appropriate policy document"` when `condition` is one of those two and `apd` is False

Keep the bases and the two conditions in module constants.

What you need to know.

`entry["schedule1"] is None` tests for a missing value without treating an empty string as missing. A list collects messages in order:

```
notes = []
notes.append("first")
notes.append("second")   # ["first", "second"]
```

Your code must pass these checks:

- A complete special entry and an ordinary entry raise no problems.
- Flag a lawful basis that is not one of the six.
- A special attribute needs an Article 9 condition.
- 9(2)(b) and 9(2)(g) need a Schedule 1 condition and an appropriate policy document.
- Return the problems in register order, not sorted.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```
# Module constant.
```

```
LAWFUL_BASES = ...

# Module constant.
NEEDS_SCHEDULE_1 = ...

# List the documentation gaps in a processing register.
def check_register(entries: list[dict]) -> list[str]: ...
```

Starter code:

```
def check_register(entries):
    return []
```

Exercise 5. Architecture design (level 4)

Screen a new use of talent data for a DPIA: a model that ranks all 40,000 employees for promotion readiness, using performance ratings, absence history and inferred health risk.

Options: Yes: large-scale special category data and profiling with significant effects, No: the data is internal and already held.

1. Is a DPIA needed?
2. When
3. If a high risk remains after mitigation

Sources

- Article 9(2)(b) relies on DPA 2018 Schedule 1 Part 1 paragraph 1 and needs an appropriate policy document; the employment condition does not cover purely contractual rights; APD needs no set form, outlines condition, principles procedures and retention; one APD can cover several purposes; record of processing activities must note the condition. (search-only: ICO guidance 'What are the conditions for processing?', 'What are the rules on special category data?' and 'Data protection and monitoring workers' (ico.org.uk), seen through search results, November 2026.)
- Schedule 1 paragraphs 6 to 28 hold 23 substantial public interest conditions and paragraph 5 requires an APD. Paragraph 8 covers racial or ethnic origin, religious or philosophical beliefs, health and sexual orientation only, and excludes measures or decisions about a particular data subject. The 2025 Act added no new paragraph; it amended paragraphs 10, 13, 14, 23 and 24. (verified: https://www.legislation.gov.uk/ukpga/2018/12/schedule/1, checked 7 November 2026.)
- Paragraph 8 equality of opportunity or treatment is the usual condition for diversity monitoring with Article 9(2)(g). (search-only: ICO guidance 'What

are the substantial public interest conditions?' and 'What about fairness, bias and discrimination?' (ico.org.uk), seen through search results, November 2026.)

- Article 35(3): large-scale special category or criminal offence data, systematic extensive profiling with significant effects and large-scale public monitoring always need a DPIA. Article 36(1): consult the Commission before processing if the DPIA shows a high risk without mitigation. The Information Commission replaced the Information Commissioner on 30 September 2026 and keeps the ICO name. (verified: https://www.legislation.gov.uk/eur/2016/679/article/35 and /article/36, checked 7 November 2026; Lewis Silkin and LexisNexis on the 30 September 2026 commencement.)
- The ICO's list of likely high-risk processing includes innovative technology such as AI combined with another criterion; two screening criteria usually indicate a DPIA. (search-only: ICO guidance 'When do we need to do a DPIA?' and 'Examples of processing likely to result in high risk' (ico.org.uk), seen through search results, November 2026.)

E1-L4 Writing the DPIA for a people model

Concept

Lesson E1-L3 showed when you need a DPIA. This lesson covers writing one for a model that scores people, such as attrition risk or promotion readiness.

UK GDPR **Article 35(7)** sets the minimum content:

1. a systematic **description** of the processing and its purposes;
2. an assessment of **necessity and proportionality**;
3. an assessment of the **risks** to people's rights and freedoms;
4. the **measures** that address those risks.

The ICO's sample template turns this into seven steps: identify the need, describe the processing, consult, assess necessity, identify and assess risks, identify measures, then sign off and record outcomes. You may adapt it.

Risks. For each risk, rate the likelihood of harm (remote, possible, probable) and its severity (minimal, significant, severe), then give an overall rating of low, medium or high. For a people model, name the harms plainly: a manager treats someone as a flight risk, or a group gets fewer promotion nominations.

Fairness belongs in the risk section. Report the test from lesson B13-L3: the model's flag rate for each group defined by a protected characteristic, the ratio between groups, and the threshold that would trigger action. A DPIA that says "the model is fair" with no figures is a statement, not an assessment.

Measures and residual risk. For each medium or high risk, record the measure, its effect (eliminated, reduced or accepted) and the residual risk.

Sign-off. Record the data protection officer's advice and who accepted each residual risk. If a high risk remains, you must consult the ICO before processing starts. Review the DPIA when the model, the data or the purpose changes.

Why it matters

A firm's DPIA for a promotion-readiness model said "bias has been considered". A year later, an internal review found women were flagged as ready at 0.6 times the rate of men with the same ratings. The DPIA held no fairness figures, no threshold and no owner, so nobody had checked. A DPIA with the flag-rate ratio and a trigger would have caught it at the first quarterly review.

Worked example: weak code

```
# DPIA, promotion-readiness model
risks: bias has been considered
measures: the model will be monitored
sign_off: project manager
```

1. **Line 2.** No harm named, no likelihood, no severity, no figures.
2. **Line 3.** No metric, no threshold, no owner, no residual risk.
3. **Line 4.** No DPO advice recorded, and nobody named as accepting each residual risk.

Worked example: strong code

```
# DPIA, promotion-readiness model, version 2
risks:
  - id: R1
    harm: a group receives fewer promotion nominations
    likelihood: possible
    severity: severe
    overall: high
    evidence: flag rate women 0.21, men 0.30, ratio 0.70 on 2025 data
measures:
  - risk: R1
```

```
11      measure: recalibrate thresholds per review cycle; quarterly flag-rate
        ratio check, action below 0.80
12      effect: reduced
3       residual: medium
14      approved_by: HR director
15  dpo_advice: proceed with the quarterly check; review at the next model
        version
4   ico_consultation: not needed, no high residual risk
```

1. **Line 4.** The harm in plain words, to people, not to the project.
2. **Line 8.** Figures from the fairness test, with the data they came from.
3. **Line 13.** The risk after the measure, which decides whether to consult the ICO.
4. **Line 16.** The Article 36 question, answered explicitly.

Cover the four parts of Article 35(7). Name each harm, rate it, put fairness figures in the risk section, record measures and residual risk, and consult the ICO if a high risk remains.

Recap card

- **Article 35(7): four required parts of a DPIA** Description and purposes, necessity and proportionality, risks to people, and the measures that address them.
- **ICO template risk scales** Likelihood: remote, possible, probable. Severity: minimal, significant, severe. Overall: low, medium, high.
- **Where fairness goes in a DPIA** In the risk section, with flag rates per group, the ratio and the threshold for action.
- **High residual risk** Consult the ICO before processing starts.

Practice

Exercise 1. Multiple choice (level 1)

Which item is not one of the four parts Article 35(7) requires in a DPIA?

- a) A return on investment calculation
- b) A description of the processing and its purposes
- c) An assessment of necessity and proportionality
- d) The measures that address the risks

Exercise 2. Multiple choice (level 2)

After measures, one risk of a people model is still rated high. What must happen before processing starts?

- a) Consult the ICO

- b) The project manager signs off the risk
- c) Nothing, as long as the DPIA is written
- d) Ask employees for consent

Why?

- r1) A high risk you cannot mitigate requires prior consultation with the ICO.
- r2) Every DPIA must be sent to the ICO.

Exercise 3. Fill the gap (level 2)

Complete the rating scales from the ICO's sample template.

```
Likelihood of harm:  remote, possible, _____(1)
Severity of harm:    minimal, significant, _____(2)
Overall risk:        low, medium, _____(3)
```

Exercise 4. Write the function (level 3)

Write `dpia_outcome(risks: list[dict]) -> tuple[str, list[str]]`. Each risk is a dict with `"id"` and `"residual"`, where `"residual"` is `"low"`, `"medium"` or `"high"`.

Return `("consult_ico", ids)` with the sorted IDs of every risk whose residual is `"high"`, if there are any. Otherwise return `("proceed", [])`.

Raise `ValueError` if the list is empty, because a DPIA with no risks assessed is not finished, or if any residual is not one of the three levels.

What you need to know.

A list comprehension with a condition keeps matching items:

```
scores = [{"name": "a", "band": "top"}, {"name": "b", "band": "low"}]
[s["name"] for s in scores if s["band"] == "top"]   # ["a"]
```

A function can return a tuple of two values: `return ("ok", [])`.

Your code must pass these checks:

- Return consult_ico with the sorted IDs of every high residual risk.
- With no high residual risk, return ("proceed", []).
- Raise ValueError for an empty list. No risks assessed means the DPIA is not finished.
- Raise ValueError for a residual level other than low, medium or high.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```
# Module constant.
LEVELS = ...
```

```python

# Whether a DPIA can proceed or needs prior consultation with the ICO.
def dpia_outcome(risks: list[dict]) -> tuple[str, list[str]]: ...
```

Starter code:

```python
def dpia_outcome(risks):
    return ("proceed", [])
```

Exercise 5. Architecture design (level 4)

Plan the DPIA for an attrition-risk model that HR business partners will see for each employee.

Options: Flag rates per group for each protected characteristic held, the ratio, and the action threshold, A statement that the vendor tested the model for bias.

1. Fairness in the risk section
2. Consultation step
3. When to review the DPIA

Sources

- UK GDPR Article 35(7) requires at least a systematic description of the processing and its purposes, an assessment of necessity and proportionality, an assessment of the risks to rights and freedoms, and the measures envisaged to address them. (search-only: Article 35(7) text as retained in UK GDPR. Not re-checked against legislation.gov.uk, which was not reachable.)
- The ICO's sample DPIA template has seven steps and rates likelihood (remote, possible, probable), severity (minimal, significant, severe) and overall risk (low, medium, high); measures record effect (eliminated, reduced, accepted) and residual risk; if a high residual risk is accepted, consult the ICO before going ahead. (search-only: ICO sample DPIA template and the Annex D template of the Age Appropriate Design Code, seen through search results and mirrored copies, November 2026.)

E1-L5 Personal data in each medallion layer

Concept

A medallion design decides where personal data lives in a readable form. Make that decision per layer, and write it down.

Bronze keeps the delivery as received, names and national insurance numbers included. Few people need it: give access to the pipeline identity and one named engineering group. Keep it only as long as reprocessing needs it.

Silver is where you **pseudonymise**. UK GDPR Article 4(5) defines pseudonymisation as processing personal data so it can no longer be attributed to a person without additional information, which is kept separately and protected. In practice:

- Replace each direct identifier with a **keyed hash**, such as HMAC-SHA256 of the employee ID with a secret key.
- Keep the key in a secret store, not in the lakehouse. Without the key, nobody can rebuild the mapping.
- Drop fields no use needs, and coarsen others: date of birth becomes an age band.

A plain hash without a key is not enough. National insurance numbers follow a known pattern, so anyone can hash every possible value and match them.

Pseudonymised data is **still personal data**: you hold the key. It lowers the risk, so it changes how you protect the data, not whether the law applies.

Gold serves aggregates. Suppress any group smaller than a threshold you agree with the data protection officer, such as fewer than 10 people, so a team of three cannot be singled out. Mask any identifying column that remains with column-level security, as lesson C9-L2 showed.

Record each layer's choices in the architecture decision record, with the reason.

Why it matters

A team hashed employee IDs in silver with plain SHA-256 and shared the tables with an analytics vendor. A vendor analyst hashed every employee ID in the firm's known format and matched them all within an hour. The hashed tables were as identifying as the originals. A keyed hash, with the key kept by the firm, would have made the match impossible.

Worked example: weak code

```
1 import hashlib
2
3
1 def mask_id(employee_id):
```

```
(2)      return hashlib.sha256(employee_id.encode()).hexdigest()
```

1. **Line 4.** No check for an empty ID, which would hash to the same value every time.
2. **Line 5.** No key. Anyone can hash every ID in the known format and match them.

Worked example: strong code

```
 1 import hashlib
 2 import hmac
 3
 4
(1) def pseudonymise(employee_id: str, key: bytes) -> str:
 6     """A keyed pseudonym for an employee ID; the key stays in the secret
       store."""
 7     if not employee_id or not key:
 8         raise ValueError("employee ID and key are both required")
(2)     return hmac.new(key, employee_id.encode(), hashlib.sha256).hexdigest()
```

1. **Line 5.** The key is a parameter, read from a secret store at run time, never hardcoded.
2. **Line 9.** HMAC-SHA256 with a secret key. Without the key, the mapping cannot be rebuilt.

Keep raw identifiers in bronze for a few people, pseudonymise with a keyed hash in silver, suppress small groups in gold, and record each choice. Pseudonymised data is still personal data.

Recap card

- **Pseudonymisation, UK GDPR Article 4(5)** Data no longer attributable to a person without additional information that is kept separately and protected.
- **Is pseudonymised data personal data?** Yes. You hold the key. It lowers the risk; the law still applies.
- **Why a keyed hash?** A plain hash of a known-format ID is matched by hashing every possible value. HMAC with a secret key prevents that.
- **Personal data per layer** Bronze raw for a named few, silver pseudonymised, gold aggregated with small groups suppressed.

Practice

Exercise 1. Multiple choice (level 1)

In which layer should direct identifiers be replaced with pseudonyms?

- a) Silver
- b) Bronze

- c) Gold only
- d) None, because access control is enough

Exercise 2. Multiple choice (level 2)

Silver holds employee IDs replaced by a keyed hash. Is it still personal data under UK GDPR?

- a) Yes
- b) No

Why?

- r1) The organisation holds the key and can attribute the data to a person, so it is pseudonymised, not anonymous.
- r2) Any data about employees is personal data, even when no one can identify anyone.

Exercise 3. Fill the gap (level 2)

Complete the plan for personal data in each layer.

```
bronze: raw, read by the pipeline identity and one _____(1) group
silver: direct identifiers replaced by a _____(2) hash, key in the secret
    store
gold:   aggregates, with groups under 10 people _____(3)
```

Exercise 4. Write the function (level 3)

Write `pseudonymise(employee_id: str, key: bytes) -> str`. Return the HMAC-SHA256 of the employee ID, encoded as UTF-8, under `key`, as a hex string. Raise `ValueError` if the ID is empty or the key is empty.

What you need to know.

`hmac.new(key, message, hashlib.sha256)` builds a keyed hash. `.hexdigest()` returns it as hex text. Both arguments must be bytes, so encode text first:

```
import hashlib
import hmac

hmac.new(b"secret", "hello".encode(), hashlib.sha256).hexdigest()[:8]   #
    '88aab3ed'
hashlib.sha256("hello".encode()).hexdigest()[:8]
    # '2cf24dba', no key
```

The same message and key always give the same result. A different key gives a different one.

Your code must pass these checks:

- Return the HMAC-SHA256 of the ID under the key, not a plain hash.

- The same ID and key always give the same pseudonym; a different key or ID gives a different one.
- Raise ValueError for an empty ID or an empty key.

Shape of the answer. The reference solution defines these names. Write the bodies yourself.

```python
# A keyed pseudonym for an employee ID.
def pseudonymise(employee_id: str, key: bytes) -> str: ...
```

Starter code:

```python
import hashlib


def pseudonymise(employee_id, key):
    return hashlib.sha256(employee_id.encode()).hexdigest()
```

Exercise 5. Architecture design (level 4)

Set the personal data rules for a performance-ratings pipeline.

Options: The pipeline identity and one named engineering group, with short retention, Everyone in the analytics workspace, so they can debug.

1. Bronze access
2. Identifiers in silver
3. Small teams in gold

Sources

- UK GDPR Article 4(5) defines pseudonymisation as processing personal data so it can no longer be attributed to a specific data subject without additional information, kept separately and subject to technical and organisational measures. (verified: https://www.legislation.gov.uk/eur/2016/679/article/4, checked 7 November 2026.)
- Pseudonymised data remains personal data when the controller can attribute it with additional information it holds. (search-only: UK GDPR recital 26 and ICO guidance on pseudonymisation, not re-checked at source: ico.org.uk refused automated requests.)
- Small-cell suppression thresholds, such as fewer than 10 people, are an organisational choice agreed with the data protection officer, not a legal figure. (unverified: Common statistical disclosure control practice.)

Track E best-practice checklist

☐ Treat every talent attribute as personal data. Flag special category data, including what a model infers.

☐ Every use of personal data has a lawful basis. Every use of special category data also has an Article 9 condition.

☐ Employers rarely rely on consent. Record a legitimate interests assessment when you use legitimate interests.

☐ Keep an appropriate policy document for the employment and substantial public interest conditions.

☐ Screen every new use of people data for a DPIA. Large-scale special category data always needs one.

☐ Govern with a frame everyone shares. Map each knowledge area to the talent domains, with an owner.

☐ Score maturity with evidence, per knowledge area and domain. Never average a gap away.

☐ Run the three-step test on every flow that leaves the UK, access included. Adequacy first, then a safeguard with a transfer risk assessment.

☐ Consult works councils and workers before go-live wherever a tool monitors people. The rules differ by country.

☐ The legal team and the data protection officer decide on compliance. These lessons teach you to ask the right questions.

Appendix: solutions and answer keys

Attempt each exercise before you read its solution. Track D answer keys are here too.

E1-L1 Personal data, special category data and the two-part test

E1-L1 exercise 1

Hints. (1) There are nine special categories. (2) Think of what membership of an organisation can reveal about someone. (3) Trade union membership is on the list.

Answer. c) Trade union membership

Trade union membership is one of the nine special categories. The others are racial or ethnic origin, political opinions, religious or philosophical beliefs, genetic data, biometric data used to identify someone, health, sex life and sexual orientation.

Common wrong answers.

- `a`: Age is a protected characteristic under the Equality Act 2010, but it is not one of the nine special categories.
- `b`: Salary is personal data, and confidential, but it is not a special category.
- `d`: An address is personal data, not special category data.

E1-L1 exercise 2

Hints. (1) What does the model output say about each person? (2) Does inferring a category count as processing it? (3) The ICO treats inferred special category data as special category data.

Answer. b) Yes, because the model infers information about health Because: r1) Inferring a special category from other data counts as processing that category.

The ICO's guidance says that inferring health, ethnicity, beliefs or sexual orientation means you are processing special category data and need an Article 9 condition.

Common wrong answers.

- `a`: Inferences count. A prediction about health is health data.

- `c`: Producing the inference is processing, whether or not anyone sees it.
- `d`: Scale matters for whether you need a DPIA, not for whether data is special category.
- `b|r2`: Right answer, wrong reason. A plain count of days absent is not health data. The model's inference about illness is.

E1-L1 exercise 3

Hints. (1) One article applies to all personal data. (2) The other applies only to special categories. (3) Article 6, then Article 9.

Answer.

```
Part 1: a lawful basis under Article 6
Part 2: a condition under Article 9
```

Every use of personal data needs an Article 6 lawful basis. Special category data needs an Article 9 condition as well.

Common wrong answers.

- g1 = `9`; g2 = `6`: The other way round. Every use of personal data needs an Article 6 basis. Special category data also needs an Article 9 condition.

E1-L1 exercise 4

Hints. (1) Put the nine names in a frozenset at module level. (2) Handle biometric before the general check. (3) `field.get("use") == "identify"` is True only when the use is set to identify.

Answer.

```python
SPECIAL_CATEGORIES = frozenset(
    {
        "racial_or_ethnic_origin",
        "political_opinions",
        "religious_or_philosophical_beliefs",
        "trade_union_membership",
        "genetic",
        "biometric",
        "health",
        "sex_life",
        "sexual_orientation",
    }
)


def is_special_category(field: dict) -> bool:
    """True when an attribute is special category data under Article 9.

    Args:
        field: Register entry with a "category" and an optional "use".
```

```
21
22      Returns:
23          Whether the attribute needs an Article 9 condition.
24      """
25      category = field["category"]
26      if category == "biometric":
27          return field.get("use") == "identify"
28      return category in SPECIAL_CATEGORIES
```

A constant holds the list, and the one conditional category gets its own branch. Age and sex stay out: they belong to the Equality Act list.

E1-L1 exercise 5

Hints. (1) Do the two lists of sensitive attributes match? (2) Can a column name hide what a field holds? (3) Is an inference data?

Answer.

- Two fields, because the GDPR list and the Equality Act list overlap only in part.
- Classify by content: a free-text field can hold health data under any name.
- Inferred attributes are special category data, so they belong in the register with their own access rules.

Separate the two lists, classify by content, and register inferences, so access rules and DPIA screening start from the truth.

Common wrong answers.

- fields = `one`: A single flag cannot say whether an attribute needs an Article 9 condition or only a fairness check.
- basis = `name`: A column called absence_note held health data in this lesson's example.
- inferred = `skip`: Inferring a special category is processing it.

E1-L2 A lawful basis for each use of talent data

E1-L2 exercise 1

Hints. (1) What agreement does a salary come from? (2) The employment contract. (3) Contract.

Answer. b) Contract

Paying salary is necessary to perform the employment contract, so the contract basis fits.

Common wrong answers.

- `a`: The employee cannot refuse payroll, so consent would not be freely given. Payroll performs the contract.
- `c`: Vital interests protects someone's life. Salary payments do not.
- `d`: Public task covers official functions set out in law, not paying staff.

E1-L2 exercise 2

Hints. (1) Who holds the power in employment? (2) Can consent be freely given when refusing feels risky? (3) Look for another basis, such as legitimate interests.

Answer. b) Employers rarely rely on consent, because the power imbalance makes it hard to give freely Because: r1) A worker who fears refusing has no genuine choice, so consent is hard to show as freely given.

The ICO treats consent as rarely appropriate for employers, because a worker's choice is not genuinely free. Legitimate interests, with a recorded assessment, usually fits voluntary analytics.

Common wrong answers.

- `a`: Consent is the hardest basis to rely on for employees, and it can be withdrawn at any time.
- `c`: It is not banned. The ICO says it can work where refusing truly has no consequences, but that is rare.
- `d`: No lawful basis is required for a type of activity. You choose the one that fits the purpose.
- `b|r2`: Right answer, wrong reason. The problem is the imbalance of power, not an expiry date.

E1-L2 exercise 3

Hints. (1) What do you need before you can test necessity? (2) The balancing test weighs the interest you named against the person's. (3) The record comes last, before processing begins.

Answer.

1. Purpose: identify the legitimate interest
2. Necessity: show the processing serves it and nothing less intrusive would
3. Balancing: weigh the person's interests, rights and freedoms against yours
4. Record the outcome before processing starts

Purpose, necessity, balancing, then a written record before processing starts.

Common wrong answers.

- You cannot weigh an interest you have not named yet. Start with the purpose.
- Record the outcome once all three parts are done, before processing starts.

E1-L2 exercise 4

Hints. (1) Both principles come from Article 5. (2) One limits purposes, the other keeps data to a minimum. (3) `limitation`, then `minimisation`.

Answer.

```
1 Purpose limitation: a lawful basis covers the purposes you specified. A
    new purpose needs its own check.
2 Data minimisation: hold only the data each purpose needs.
```

Purpose limitation and data minimisation are Article 5 principles. Together they stop one dataset quietly serving every new idea.

Common wrong answers.

- g1 = `minimisation`; g2 = `limitation`: The other way round: purpose limitation, data minimisation.

E1-L2 exercise 5

Hints. (1) Which uses does the law require? (2) Which use is a new purpose? (3) A new purpose needs its own basis check.

Answer.

- Right-to-work checks are required by law, so legal obligation fits.
- Training records support the employment relationship. Record which basis you use and why.
- The attrition model is a new purpose. It needs its own basis check and assessment, and only the fields it uses.

Legal duties use legal obligation. Running the employment relationship uses contract or legitimate interests. A new analytics purpose gets its own assessment.

Common wrong answers.

- right_to_work = `consent`: The check is a legal duty. Consent would be misleading, because the worker cannot refuse.
- attrition = `inherit`: Purpose limitation: payroll's basis does not cover a new analytics purpose.

- attrition = `consent`: Consent rarely works for employees, and withdrawals would leave holes in the model.

E1-L3 Article 9 conditions, policy documents and DPIA screening in HR

E1-L3 exercise 1

Hints. (1) Monitoring equality is a substantial public interest. (2) Which Schedule 1 paragraph names equality? (3) Paragraph 8.

Answer. a) Article 9(2)(g) with Schedule 1 paragraph 8, equality of opportunity or treatment

Article 9(2)(g) with Schedule 1 paragraph 8 covers reviewing equality of opportunity or treatment between groups.

Common wrong answers.

- `b`: Paragraph 1 covers obligations and rights in employment law. Diversity monitoring uses the equality condition in paragraph 8.
- `c`: Consent is rarely appropriate for employees, and monitoring has its own condition.
- `d`: You process individual records before you aggregate them, so you need a condition.

E1-L3 exercise 2

Hints. (1) What does paragraph 8 allow you to do? (2) Is a shortlist a decision about a person? (3) Monitoring and decisions need separate data and separate conditions.

Answer. b) Paragraph 8 supports monitoring equality across groups, not decisions about one person Because: r1) The ICO says the equality condition cannot be relied on when processing is for decisions about a particular individual.

Keep equality monitoring data apart from decisions about individuals. Paragraph 8 does not cover them.

Common wrong answers.

- `a`: Purpose limitation: the data was collected for monitoring, under a condition that does not cover decisions.
- `c`: Racial or ethnic origin is a special category.
- `d`: Frequency is not the issue. The use is.

- `b|r2`: Right answer, wrong reason. Retention periods are set in your policy, but the problem here is using monitoring data for individual decisions.

E1-L3 exercise 3

Hints. (1) Part 1 of Schedule 1 starts with the employment condition. (2) APD stands for appropriate ... document. (3) Paragraph `1`, and `policy`.

Answer.

```
Article 9(2)(b) in the UK needs Schedule 1, Part 1, paragraph 1
and an appropriate policy document that names the condition and the
    retention rules.
```

The employment condition is Schedule 1, Part 1, paragraph 1, and it needs an appropriate policy document.

Common wrong answers.

- g1 = `8`: Paragraph 8 is equality of opportunity or treatment, a substantial public interest condition. The employment condition is paragraph 1.

E1-L3 exercise 4

Hints. (1) Loop over the entries once, appending messages as you go. (2) Check the basis, then the Article 9 condition, then the two documentation rules. (3) Only 9(2)(b) and 9(2)(g) need Schedule 1 and the policy document.

Answer.

```python
LAWFUL_BASES = frozenset(
    {
        "consent",
        "contract",
        "legal_obligation",
        "vital_interests",
        "public_task",
        "legitimate_interests",
    }
)
NEEDS_SCHEDULE_1 = frozenset({"9(2)(b)", "9(2)(g)"})


def check_register(entries: list[dict]) -> list[str]:
    """List the documentation gaps in a processing register.

    Args:
        entries: Register entries with lawful basis, Article 9 condition,
            Schedule 1 condition and policy document status.

    Returns:
        One message per problem, in register order.
```

```
    """
    problems: list[str] = []
    for entry in entries:
        name = entry["attribute"]
        if entry["lawful_basis"] not in LAWFUL_BASES:
            problems.append(f"{name}: no lawful basis")
        if entry["special"] and entry["condition"] is None:
            problems.append(f"{name}: no Article 9 condition")
        if entry["condition"] in NEEDS_SCHEDULE_1:
            if entry["schedule1"] is None:
                problems.append(f"{name}: no Schedule 1 condition")
            if not entry["apd"]:
                problems.append(f"{name}: no appropriate policy document")
    return problems
```

Encoding the register rules as a check means every new attribute is tested the same way, and the gaps show up before an auditor finds them.

E1-L3 exercise 5

Hints. (1) Count the risk factors: scale, special category data, significant effects. (2) What is a DPIA for, if not to shape the design? (3) What does Article 36 prior consultation mean?

Answer.

- Inferred health risk across 40,000 people is large-scale special category data, and ranking for promotion is profiling with significant effects. Both always need a DPIA.
- The DPIA comes before processing, so its findings can change the design, for example by dropping the health inference.
- A high risk you cannot reduce means consulting the ICO first.

Screen early, assess before processing, and consult the ICO when a high risk remains.

Common wrong answers.

- need = `not_needed`: Holding the data already changes nothing. A new use with these risk factors always needs a DPIA.
- when = `after`: A DPIA after the run cannot shape the design. It comes first.
- residual = `proceed`: An unmitigated high risk needs prior consultation with the ICO.

E1-L4 Writing the DPIA for a people model

E1-L4 exercise 1

Hints. (1) Article 35(7) is about risks to people. (2) Three options appear in the lesson's list of four. (3) The business case is not a DPIA part.

Answer. a) A return on investment calculation

Description, necessity and proportionality, risks, and measures. A business case belongs elsewhere.

Common wrong answers.

- `b`: The description is the first required part.
- `c`: Necessity and proportionality is the second required part.
- `d`: Measures are the fourth required part.

E1-L4 exercise 2

Hints. (1) Which rating triggers prior consultation? (2) Does every DPIA go to the ICO? (3) High residual risk means the ICO first.

Answer. a) Consult the ICO Because: r1) A high risk you cannot mitigate requires prior consultation with the ICO.

Prior consultation applies when a high risk remains after the measures.

Common wrong answers.

- `b`: Sign-off records who accepted the risk, but a high residual risk still needs the ICO first.
- `c`: Writing the DPIA does not remove the duty to consult on a high residual risk.
- `d`: Consent does not replace prior consultation, and it is rarely valid for employees.
- `a|r2`: Right action, wrong reason. Only a high risk that remains after measures triggers prior consultation.

E1-L4 exercise 3

Hints. (1) Each scale has three steps. (2) The top of likelihood is more than possible. (3) `probable`, `severe`, `high`.

Answer.

```
Likelihood of harm:  remote, possible, probable
Severity of harm:    minimal, significant, severe
Overall risk:        low, medium, high
```

Remote, possible, probable. Minimal, significant, severe. Low, medium, high.

Common wrong answers.

- g1 = `likely`: The ICO template uses remote, possible, probable.

E1-L4 exercise 4

Hints. (1) Check for an empty list and unknown levels before anything else. (2) Collect every high risk's ID, then sort them. (3) Return `("consult_ico", ids)` only when the list of high IDs is not empty.

Answer.

```python
LEVELS = frozenset({"low", "medium", "high"})


def dpia_outcome(risks: list[dict]) -> tuple[str, list[str]]:
    """Whether a DPIA can proceed or needs prior consultation with the ICO.

    Args:
        risks: Dicts with "id" and "residual" ("low", "medium" or "high").

    Returns:
        ("consult_ico", sorted high-risk IDs) if any residual risk is high,
        otherwise ("proceed", []).

    Raises:
        ValueError: If no risks are given, or a residual level is unknown.
    """
    if not risks:
        raise ValueError("a DPIA with no risks assessed is not finished")
    for risk in risks:
        if risk["residual"] not in LEVELS:
            raise ValueError(f"{risk['id']}: unknown residual level {risk['residual']}")
    high = sorted(risk["id"] for risk in risks if risk["residual"] == "high")
    if high:
        return ("consult_ico", high)
    return ("proceed", [])
```

Validate first, then collect every high residual risk. One high risk is enough to require prior consultation, and the list tells the DPO which.

E1-L4 exercise 5

Hints. (1) What makes a fairness claim checkable? (2) Whose views does Article 35(9) mention? (3) Does the model stay the same for ever?

Answer.

- Fairness is a risk to people, so it needs figures and a trigger in the risk section.
- Article 35(9) and the ICO's monitoring guidance both point to seeking staff views.
- A DPIA describes one version of the processing. When that changes, so must the assessment.

Figures for fairness, recorded staff views, and a review trigger keep the DPIA true to the model as it runs.

Common wrong answers.

- fairness = `statement`: A vendor's claim is not your assessment. Test on your own population, as lesson B13-L3 shows.
- consult = `skip`: Advice to managers still affects how people are treated. Seek views, as lesson E3-L3 explains.
- review = `never`: Models are retrained and purposes drift. A DPIA that never changes stops describing the real processing.

E1-L5 Personal data in each medallion layer

E1-L5 exercise 1

Hints. (1) Which layer keeps the delivery as received? (2) Where do canonical, cleaned tables live? (3) Silver.

Answer. a) Silver

Bronze stays raw for reprocessing. Silver is the first layer most analysts read, so pseudonymise there.

Common wrong answers.

- `b`: Bronze keeps the delivery as received, so reprocessing stays possible.
- `c`: By gold, the readable identifiers have already spread through silver.
- `d`: Access control limits who reads the data. Pseudonymisation limits what a reader learns.

E1-L5 exercise 2

Hints. (1) Who holds the key? (2) Can anyone in the organisation reverse it? (3) Pseudonymised, not anonymous.

Answer. a) Yes Because: r1) The organisation holds the key and can attribute the data to a person, so it is pseudonymised, not anonymous.

You can attribute it with the key you hold, so it remains personal data with a lower risk.

Common wrong answers.

- `b`: Article 4(5) describes pseudonymised data: attributable with the separately kept information. You hold that information.
- `a|r2`: Right answer, wrong reason. Truly anonymous data is not personal data. This data is pseudonymous because you hold the key.

E1-L5 exercise 3

Hints. (1) Very few people read bronze. (2) The hash needs a secret. (3) `engineering`, `keyed`, `suppressed`.

Answer.

```
bronze: raw, read by the pipeline identity and one engineering group
silver: direct identifiers replaced by a keyed hash, key in the secret
    store
gold:   aggregates, with groups under 10 people suppressed
```

Bronze for a named few, a keyed hash in silver, small groups suppressed in gold.

Common wrong answers.

- g2 = `plain`: A plain hash of a known format can be reversed by hashing every possible value. Use a keyed hash.

E1-L5 exercise 4

Hints. (1) Import `hmac` and `hashlib`. (2) Encode the ID to bytes before hashing. (3) Check for an empty ID or key first, and raise `ValueError`.

Answer.

```python
import hashlib
import hmac


def pseudonymise(employee_id: str, key: bytes) -> str:
    """A keyed pseudonym for an employee ID.

    Args:
        employee_id: The direct identifier to replace.
        key: The secret key, read from a secret store at run time.

    Returns:
        The HMAC-SHA256 of the ID under the key, as a hex string.

    Raises:
        ValueError: If the ID or the key is empty.
```

```
    """
    if not employee_id or not key:
        raise ValueError("employee ID and key are both required")
    return hmac.new(key, employee_id.encode("utf-8"),
hashlib.sha256).hexdigest()
```

HMAC-SHA256 with a secret key is deterministic, so joins still work, and it cannot be reversed by hashing every possible ID without the key.

E1-L5 exercise 5

Hints. (1) Who needs raw identifiers? (2) Can a known-format ID be guessed? (3) What does a group of three reveal?

Answer.

- Raw identifiers stay with the few who must reprocess them.
- A keyed hash cannot be matched by hashing every possible ID.
- Small groups in an aggregate can single people out.

Narrow bronze, keyed pseudonyms in silver, and suppression in gold keep each layer's risk in proportion.

Common wrong answers.

- bronze = `all`: Bronze holds raw identifiers. Debugging should use silver, or a named few.
- silver = `plain`: A plain hash of a known ID format is matched by hashing every possible value.
- gold = `show`: A team of three in a ratings report identifies each person.